REGISTRO DE BACKEND - SEMANA 25

Descomplicando o OAuth: autorização segura para APIs

1. Estudo teórico

1.1 Caso prático – Plano de implementação OAuth

1. Escolha do fluxo OAuth

Utilizaria o Authorization Code Flow, pois permite que os usuários autorizem o acesso aos seus dados financeiros sem compartilhar suas senhas com o aplicativo.

2. Configuração necessária

- Registrar a aplicação no provedor OAuth.
- Definir os escopos de acesso necessários.
- Configurar URLs de redirecionamento seguras.
- Garantir que apenas usuários autorizados tenham acesso aos dados.

3. Gerenciamento de tokens

Os tokens devem possuir tempo de expiração definido. Quando expirarem, poderão ser renovados por meio de um mecanismo seguro, evitando que o usuário precise realizar login constantemente.

2. Execução – Plano de implementação

A implementação do OAuth será realizada utilizando o Authorization Code Flow, por ser adequado para aplicações web e oferecer maior segurança no processo de autorização.

Primeiramente, a aplicação será registrada no provedor OAuth. Depois, serão definidos os escopos de acesso e as URLs de redirecionamento.

Os tokens serão armazenados de forma segura, terão prazo de validade e serão renovados quando necessário.

Essas medidas ajudam a proteger os dados financeiros e controlar o acesso à API.

3. Perguntas da atividade

1. Como vocês explicariam a importância de escolher o fluxo OAuth adequado para nossa API e qual fluxo vocês recomendariam?

Escolher o fluxo adequado é importante para garantir a segurança dos usuários e dos dados. Recomendo o Authorization Code Flow, pois permite autorizar o acesso sem compartilhar senhas com o aplicativo.

2. Quais são os passos fundamentais para configurar corretamente o OAuth, desde o registro da aplicação até a definição dos escopos?

Primeiro, registrar a aplicação no provedor OAuth, configurar as URLs de redirecionamento e definir os escopos necessários. Também é importante configurar o gerenciamento dos tokens.

3. De que maneira a gestão de tokens (expiração e renovação) contribui para a segurança da nossa API?

A expiração limita o tempo de utilização dos tokens, reduzindo riscos de acesso indevido. A renovação segura permite manter o acesso sem exigir um novo login a todo momento.

4. Como vocês comunicariam essa estratégia para a equipe técnica, garantindo que todos estejam alinhados com as melhores práticas de OAuth?

Realizaria uma reunião com a equipe para apresentar o fluxo escolhido, as configurações e os cuidados com os tokens. Também compartilharia a documentação para que todos sigam os mesmos padrões de segurança.